

Mercury API - Guía de Autenticación y Permisos

Base URL local: <http://localhost:8000> Documentación interactiva (Swagger): <http://localhost:8000/docs>

Usuarios de prueba

Todos usan la misma contraseña: 12345678

Nombre	Email	Rol	Sucursal
Oscar Magana Jaime	admin@oscarmajai.dev	AdministradorSistema	(acceso global)
Diego Martinez	diego@mercury.com	AdministradorSistema	(acceso global)
Diana Ayala	dayala@oscarmajai.dev	Cajero	La Piedad Centro
Heriberto Flores	hflores@gmial.com	Cocina	Plaza Colibries

Nota: AdministradorSistema no tiene sucursal asignada porque tiene acceso global al sistema. Los roles Cajero y Cocina aún no tienen permisos activos - sus módulos (POS, restaurante) están pendientes de implementación.

Flujo de autenticación

1. Login

POST /api/auth/login

Body:

```
{
  "email": "admin@oscarmajai.dev",
  "password": "12345678",
  "rememberMe": false
}
```

Para AdministradorSistema el campo sucursalId es opcional y se ignora. Para Cajero y Cocina, si se envía sucursalId, debe coincidir con la sucursal asignada al usuario en BD.

Respuesta 200 OK:

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "token_type": "Bearer",
  "expires_in": 3600,
  "refresh_token": "dGhpcyBpcyBhIHJlZnJlc2ggdG9rZW4...",
  "refresh_expires_in": 604800,
  "user": {
    "id": "uuid-del-usuario",
    "full_name": "Oscar Magana Jaime",
  }
}
```

```

    "email": "admin@oscar:majai.dev",
    "role": "AdministradorSistema",
    "branch_id": null
  }
}

```

Duración de tokens:

	rememberMe: false	rememberMe: true
token (access)	60 minutos	7 días
refresh_token	7 días	30 días

2. Usar el token en requests protegidos

Incluir el token en el header de cada request:

Authorization: Bearer <token>

3. Obtener datos del usuario actual

GET /api/auth/me

Authorization: Bearer <token>

Respuesta 200 OK:

```

{
  "id": "uuid-del-usuario",
  "full_name": "Oscar Magana Jaime",
  "email": "admin@oscar:majai.dev",
  "role": "AdministradorSistema",
  "branch_id": null
}

```

4. Renovar el token (refresh)

Cuando el token expira, usarlo para obtener uno nuevo sin volver a hacer login. El refresh_token se rota en cada uso (el anterior queda inválido).

POST /api/auth/refresh

Body:

```

{
  "refreshToken": "<refresh_token_anterior>"
}

```

Respuesta 200 OK: mismo formato que /login.

5. Logout

Invalida el token activo y el refresh_token. Ambos quedan en blacklist.

POST /api/auth/logout

Authorization: Bearer <token>

Body:

```
{
  "refreshToken": "<refresh_token>"
}
```

Respuesta: 204 No Content

Roles y permisos

Los permisos se asignan por rol y se validan en cada endpoint. El sistema carga los permisos en caché al arrancar la app.

Permisos activos por rol

Permiso	AdministradorSistema	Administrador	Cajero	Cocina
usuarios:listar	Si	Si	-	-
usuarios:ver	Si	Si	-	-
usuarios:crear	Si	Si	-	-
usuarios:editar	Si	Si	-	-
usuarios:eliminar	Si	Si	-	-
sucursales:listar	Si	Si	-	-
sucursales:ver	Si	Si	-	-
sucursales:crear	Si	-	-	-
sucursales:editar	Si	-	-	-
sucursales:eliminar	Si	-	-	-
permisos:ver	Si	Si	-	-
permisos:editar	Si	-	-	-

Los módulos pos, inventario, restaurante y reportes fueron removidos de la BD - sus permisos se agregarán cuando se implementen esos endpoints.

Endpoints disponibles

Auth - /api/auth

Método	Ruta	Permiso	Descripción
POST	/api/auth/login	-	Iniciar sesión
GET	/api/auth/me	token válido	Datos del usuario actual
POST	/api/auth/refresh	-	Renovar access token
POST	/api/auth/logout	token válido	Cerrar sesión

Usuarios - /api/users

Método	Ruta	Permiso requerido	Descripción
GET	/api/users	usuarios:listar	Listar usuarios
POST	/api/users	usuarios:crear	Crear usuario
GET	/api/users/{id}	usuarios:ver	Ver usuario
PUT	/api/users/{id}	usuarios:editar	Editar usuario
DELETE	/api/users/{id}	usuarios:eliminar	Eliminar usuario (soft delete)

Body para crear usuario (POST /api/users):

```
{
  "email": "nuevo@ejemplo.com",
  "full_name": "Nombre Completo",
  "password": "contraseña123",
  "role": "Administrador",
  "branch_id": "uuid-de-sucursal"
}
```

branch_id es requerido para roles Administrador, Cajero y Cocina. Para AdministradorSistema se ignora. Valores válidos de role: AdministradorSistema, Administrador, Cajero, Cocina.

Sucursales - /api/branches

Método	Ruta	Permiso requerido	Descripción
GET	/api/branches	sucursales:listar	Listar sucursales
POST	/api/branches	sucursales:crear	Crear sucursal
GET	/api/branches/{id}	sucursales:ver	Ver sucursal
PUT	/api/branches/{id}	sucursales:editar	Editar sucursal

Método	Ruta	Permiso requerido	Descripción
DELETE	/api/branches/{id}	eliminar sucursales:eliminar	Eliminar sucursal (soft delete)

Body para crear/editar sucursal:

```
{
  "nombre": "Sucursal Centro",
  "direccion": "Av. Principal 123",
  "telefono": "555-1234"
}
```

Administrador solo ve y edita su propia sucursal. AdministradorSistema tiene acceso a todas.

Permisos - /api/permissions

Método	Ruta	Permiso requerido	Descripción
GET	/api/permissions/roles	permisos:ver	Listar roles con sus permisos
GET	/api/permissions/roles/{id}	permisos:ver/{id}	Ver un rol específico
PUT	/api/permissions/roles/{id}	permisos:editar/{id}	Actualizar permisos de un rol
GET	/api/permissions/permisos	permisos:ver	Listar todos los permisos disponibles
POST	/api/permissions/cache/refresh	permisos:recargar	Forzar recarga del caché de permisos

Body para actualizar permisos de un rol (PUT /api/permissions/roles/{id}):

```
{
  "permiso_ids": [1, 2, 3, 4, 5]
}
```

Los IDs se obtienen primero llamando a GET /api/permissions/permisos.

Ejemplos rápidos con curl

Login como administrador del sistema

```
curl -X POST http://localhost:8000/api/auth/login \
  -H "Content-Type: application/json" \
  -d '{"email": "admin@oscar:majai.dev", "password": "12345678"}'
```

Listar usuarios (con token)

```
curl http://localhost:8000/api/users \
  -H "Authorization: Bearer <token>"
```

Listar roles y permisos

```
curl http://localhost:8000/api/permissions/roles \
  -H "Authorization: Bearer <token>"
```

Errores comunes

Código HTTP	code en body	Causa
401	INVALID_CREDENTIALS	Email o contraseña incorrectos, o usuario sin sucursal asignada
401	INVALID_TOKEN	Token expirado, inválido o revocado (logout previo)
403	FORBIDDEN	El rol del usuario no tiene el permiso requerido
404	USER_NOT_FOUND / BRANCH_NOT_FOUND / ROL_NOT_FOUND	Recurso no existe
409	EMAIL_ALREADY_EXISTS	Ya hay un usuario con ese email
422	BRANCH_REQUIRED	Se intentó crear un Cajero/Cocina/Administrador sin sucursal